Verilog Remediations

Last updated 8/21/2026

The following document enumerates the remediations for each Verilog audit finding.

H-01 Failed CCIP messages can permanently lock delivered ERC-20s

- Fix commit: Acknowledge
- Solution: This comes down to preference. The assumption for this contract is the owner does not ever control user funds. The assumption is that the message is constructed as the user wants it to be. In the case of local refunds, the desired behavior is to send back to the source chain. If it's impossible to refund, the desired behavior is to send to the local refund address.

H-02 Synchronous-only deallocation locks capital in a cooldown or asynchronous child

- Fix commit: Acknowledge with commit 067cdc0f7605baade4c3cd0b1f7b0c7f950e7994
- Solution: StakedAsset is an async vault. Our assumption is GenericMorphoAdapter will only be used with standard ERC4626 vaults. Added a NatSpec comment about it.

M-01 Inbound payload first word is actionAndId ; Legacy encoding is misread

- Fix commit: a5c83bc99e133fe5383d3782882ae0b526a48688
- Solution: Modified our custom adapter's typeAndVersion to make it easily distinguishable.

M-02 Zero beneficiary passes validation and can lose bridged funds

- Fix commit: e89a0fefea21033ee3253d2d2946eeadea7e0e3cv

- Solution: Directly reject an empty bytes32 beneficiary address.

M-03 Committed cooldown principal is gated on entry-side switches, with no escape hatch

- Fix commit: (Waiting on feedback from Chainlink for this one)
- Solution:

M-04 Fee-exclusive marking permits externalization of the child's exit fee

- Fix commit: 267e13bee2493fc4b96ee3a5034f4e8d7a6280e9
- Solution: Change `realAssets` to use `previewRedeem` internally, so that the reported value includes withdrawal fees and reflects the assets obtainable by redeeming the adapter's current share balance.

M-05 Donated shares count at zero allocation and can never be permissionlessly removed

- Fix commit: 51cfcc3be55c1fc66666f437e8175c7820cc2918
- Solution: Included the `_position` function to be used when computing the `newAllocation` in both `allocate`, and `deallocate` , and modify `realAssets` to verify if a previous allocation was made before returning the position amount.

L-01 Failed UNSTAKE / CANCEL_COOLDOWN messages stay permanently unresolved

- Fix commit: fd3e5f13e442ed3c39edbd076521197233b65f7b
- Solution: In the catch block section of the `ccipreceive` we include a check that prevents paths without tokens from being marked as `BASIC` error code, but we left the `MessageFailed` event emission.

L-02 Solana path always assumes 9 decimals (USDC is 6)

- Fix commit: Acknowledge
- Solution: This is only if we intent to use the UI code inside the repo, CL confirmed said code is not for production, and its knowingly faulty, nothing to

do here, tenbin dos not plan on using it.

L-03 A single static liquidityData blob cannot serve both allocation directions

- Fix commit: 8d3db2816e331db1426942f4e3225698ea1cb2a7
- Solution: Check if `minShares`, or `maxShares` is zero, if they are the slippage check is skipped.

L-04 Permissionless dust returns can exhaust the shared native CCIP reserve

- Fix commit: (Waiting on extra feedback for this one)
- Solution: N/A

L-05 Inflation-resistance requirement removed while the target set was widened

- Fix commit: Acknowledge with commit 69caa76b780845c5f9f87a3464f858c4986eadb9
- Solution: When deploying an adapter, it is up to the adapter deployer and vault owner to check vaults are inflation resistant. The morpho v2 vault additionally includes a timelock for new adapters, which gives deployers sufficient time to ensure the adapter is safe.

  Added a comment to the adapter code to clarify this:

  The configured ERC4626 vault MUST be resistant to inflation/donation attacks, for example through virtual shares/assets or a provably adequate initial seed that cannot be controlled or recovered by an attacker. This adapter does not enforce inflation resistance on-chain; deployers and curators MUST verify the target vault before admission.

L-06 Staked-asset redeem passes validation but can never execute

- Fix commit: Acknowledge

- Solution: To save a bit of gas, tenbin will keep this code as-is. Given the transaction fails, it is not a risk. The bebop hook user will be responsible for ensuring they do not try to redeem staked assets.

L-07 Caller-chosen owner defeats the write-once registry guarantee

- Fix commit: b5a6bc92ffad5abaf135bba97a0d3ed80513a5a9
- Solution: Add an explicit identity check in the constructor to reject self-referential deployments at the point of creation, and a self referential error.

I-01 Gate manager can be address(0) , which locks the vault

- Fix commit: cb36964ee57727f348e47199208f5ed3140284d6
- Solution: Check and reject if new manager is zero address.

I-02 Unused fee roles and outdated docs left after the Tenbin fork

- Fix commit: 4ce82c1b4dbccfb95a2931d6f39bd038c194258e
- Solution: Delete reported unused variables.

I-03 UI shows Success when the vault action actually failed

- Fix commit: Acknowledge
- Solution: Upon talking to Chainlink they mentioned the UI in the project its not completely done and its more of a test tool than an actual production level UI, regardless Tenbin has no plans to use this UI code.

I-04 Fail-open cooldown authorization bypasses the file's own conversion rail

- Fix commit: 39f8c98c0915e1b76e694ed0ddaa931e51a0ead2
- Solution: Normalize `message.sender` once with `_normalizeToBytes32()` before cooldown authorization,
  storage, or event emission, and reuse the normalized value throughout processMessage().

I-05 Each order signer must separately call setRecipientStatus

- Fix commit: Acknowledge
- Solution: This is a known feature, works as designed.